

中国研究生网络安全创新大赛

作品报告

作品名称：密证 CredProof——面向 AI 工具的凭据泄露验证
与受控修复系统

提交日期：待填

填写说明

1. 所有参赛项目必须为一个基本完整的设计。作品报告书旨在能够清晰准确地阐述（或图示）该参赛队的参赛项目（或方案）。
2. 作品报告采用A4纸撰写。除标题外，所有内容必需为宋体、小四号字、1.5倍行距。
3. 作品报告中各项目说明文字部分仅供参考，作品报告书撰写完毕后，请删除所有说明文字。（本页不删除）
4. 作品报告模板里已经列的内容仅供参考，作者可以在此基础上增加内容或对文档结构进行微调。
5. 为保证网评的公平、公正，作品报告中应避免出现作者所在学校、院系和指导教师等泄露身份的信息。一经发现，取消作品参赛资格。

目录

摘要	3
第一章 作品概述	4
第二章 作品设计与实现	5
第三章 作品测试与分析	7
第四章 创新性说明	9
第五章 总结	9
参考文献	10

摘要

本作品面向本地 AI 工具中无硬编码、但可能经日志、异常和嵌套返回外泄的运行时凭据，构建可追溯的诊断与修复原型。系统使用本地模型提出假设和补丁，由程序依据当前对象上的实际泄露证据授权修改，并在隔离环境中检查凭据通道、认证行为及异常分支。单页界面分别展示模型判断、程序确认、候选验收与任务完成状态，材料可导出并重新执行检查。同一冻结轮次的八个合成案例中，反馈 Agent 修复四个问题例，正常代码均未被实际修改；完整任务为六例，另两例因工具调用格式问题未完成。一个案例保存了失败补丁、真实反馈与再次修复的完整过程。作品的特点是把模型建议与执行权限、验收结论分开，为小型授权工具提供可检查的修复流程。当前结果限于受控 Python 轮廓和固定条件，不代表通用漏洞修复能力。

关键词：运行时凭据；本地智能体；受控修复；证据绑定；可复检材料

第一章 作品概述

1.1 问题与目标

小型 AI 工具通常从环境变量取得认证凭据，再调用服务。源代码不包含真实密钥，并不意味着执行时不会泄露：参数可能被辅助函数记录，异常细节可能进入日志，调试结果可能把嵌套认证数据返回给调用者。另一方面，模型也可能把公开字段或正常认证调用误认为泄露，提出不必要的修改。

密证面向自有或授权、经过预先审查的 Python 工具，回答三个问题：是否在指定条件下真实观察到凭据外泄；候选修改是否保留功能并消除该外泄；当前报告是否仍对应被检查的对象。作品提供本地运行、受限工具调用、候选副本、单页结果展示和可复检材料，帮助使用者检查修复依据和失败原因。

1.2 相关工作与作品定位

作品复用 Qwen-Agent 的 Agent 循环、Qwen3-Coder 模型和 Ollama 推理能力，不训练或自称研发基础模型[1 - 3]。模式扫描、测试驱动修复、摘要绑定和 CI 验收都有既有实践；项目不将这些基础思想称为首创。本次对照 A 是项目自行实现的通用启发式修复程序，B 是一次生成，C 是有工具反馈的 Agent；它们不等于 Gitleaks、TruffleHog 或其他成熟产品的效果。

核心实现是在一个有限任务中，统一组织实际证据、修改权限、必要验收条件和过程展示。模型负责提出候选，固定程序负责授权和验收。规范 CI 也可以实现这些控制，作品的价值在于形成可运行、可查看、可复检的完整小型组件。

1.3 应用场景

适用于教学实验、小型本地认证工具，以及组织内部已授权组件的修复流程验证。开发者可先观察当前对象的实际表现，再评估模型建议是否必要、是否改坏功能。现阶段不开放任意仓库上传，不检查真实云账户，不对外部系统发起检测，也不声称已经完成云凭据撤销或轮换。

第二章 作品设计与实现

2.1 系统组成

系统由本地单页及 Python 后端、受控会话、Agent 接口、隔离执行器、固定裁判和材料导出复检模块组成。用户选择白名单案例，页面呈现原代码、当前候选、模型原文、程序证据与独立状态。历史记录明确标识为回放，新推理生成独立目录，不覆盖历史结果。

会话先固定原始对象和规则，在三个公开认证条件下形成共享初始证据。模型可调用读取代码、运行结构化条件、取得证据、提交补丁、验证候选五类工具，不提供任意 Shell。每个请求、响应、调用实参、工具回执和候选内容保留到记录中。正文中的工具标签不执行，只有经过协议解析与参数校验的原生工具调用才派发。



图 1 运行证据约束下的候选修复与验收流程

2.2 凭据使用契约

被测工具统一实现 `tool.run(request, auth_service)`。有效请求包含非空 `request_id`、`resource`、1 至 5 的整数 `units`，以及可选布尔 `debug`。工具从指定

环境变量取得随机合成凭据，并且必须对本地 mock 认证调用一次；这条通道允许携带凭据。无效输入不得调用认证，成功、拒绝和服务异常须维持各自约定响应。

返回内容与键、异常文本、stdout、stderr、logging 均不得出现执行侧注入的完整凭据。验证器在隔离外按固定矩阵比较功能与禁止通道，给模型的反馈经过脱敏。凭据没有真实账户，不执行在线有效性验证。检测限于完整明文值，不覆盖分段、编码、加密或全部隐蔽通道。

2.3 修改授权与隔离执行

提交候选前，程序核对原始对象、规则和触发条件的摘要关系，仅当前有效泄露证据可授权修改；没有证据时保留原代码，模型疑点仍完整记录。补丁只写候选副本，不改原工具、原仓库 index、需求、裁判或执行设施。受限语法检查禁止反射、文件读取、任意导入、网络和进程操作等超出轮廓的行为。

候选通过既有 WSL/Linux 隔离设施执行，使用命名空间、只读挂载、资源限制及系统调用约束。OS 隔离用于限制候选对宿主的影响，不能据此声称同进程 Python 裁判能抵抗任意恶意内省。可信需求、裁判和操作者仍是系统信任基础。

2.4 完成控制和可复检材料

对当前选中对象完成全部必要检查且 PASS，执行器才形成完成状态；FAIL 保留具体问题，必要检查不可用则不能算通过。模型循环结束、模型自述成功、最终原对象碰巧合格，均不自动代表任务完成。框架调用受总次数、候选数、上下文和时间约束，超时或错误停止，不切换云模型。

材料包包含原始与当前副本、可信需求、配置、报告、轨迹、校验信息及复检依赖源码。复检先判断历史报告与当前材料的一致性，再重新执行固定检查。旧报告失效不强制新对象 FAIL，新对象可能通过；普通哈希仅检查内容一致，不是数字签名或第三方认证。独立复检不需要模型，但需要已经准备和验收的隔离运行设施。

当前候选版还核对导出输入及缓存材料：源文件、候选、规则或材料发生变化后，旧包与旧复检不能继续作为当前结果复用。复检分别报告历史报告适用性、历史材料完整性和当前验收；材料完整性为 INTACT、DEGRADED 或 UNKNOWN。清单中的可选轨迹缺失可标为 DEGRADED，不自动把当前独立验收 PASS 改成 FAIL；必要材料缺失则

按无法核对处理。INTACT 也不证明未声明的历史事件齐全。这些交付完善不追溯计入下章历史八例成绩。

第三章 作品测试与分析

3.1 固定测试设计

本章统一采用 20260929t095000z-holdout8 的完整结果，对应源码快照 b4cb91ef67ae2d14d6cc37f9e18cf6c23e36e8ea[4]。8 个自建模板包含 4 个泄露案例和 4 个正常案例，分别覆盖辅助函数参数日志、拒绝分支输出、异常跨函数传播、嵌套返回，以及正确认证封装、公开错误、独立脱敏结构和公开诊断信息。

模板在运行方法前具有预定义需求、标签和断言，但由开发过程构造，共享部分辅助代码，并非外部独立盲测或八个统计独立样本。此后全部 14 例均作为已知回归案例。每个对象检查固定 13 个条件；三项公开初始诊断由 A/B/C 共享，不计作 Agent 自主发现。

该轮使用 Qwen-Agent 0.0.34、Ollama 0.34.4、qwen3-coder:30b Q4_K_M 和 16K 上下文。A 为固定程序；B 一次模型生成；C 最多 12 次模型请求、最多 3 个候选，模型和裁判固定。本轮无在线真实账户验证。监督命令退出 0，冻结文件保持一致。新客户端、单页完善和后续两例复测与本章历史成绩分开。

3.2 完整对照结果

方法	问题修复	正常通过	对象通过	任务完成	误修改
A 固定程序	3/4	4/4	7/8	7/8	0/4
B 一次生成	1/4	4/4	5/8	4/8	0/4
C 反馈模型	4/4	4/4	8/8	6/8	0/4

“合格修复”指问题例的最终对象满足固定检查；“完整任务”要求执行器对当前对象形成完成状态。C 的 h05/h06 仅输出正文工具标签，没有原生调用和有效诊断；最终独立检查发现原文件合格，仍应记录任务未完成。B 的 h07 原文认为正常，但输出 JSON 无效，同样不能以最终对象 PASS 补作任务完成。

正常例没有实际被改坏，不等于没有误报。A 对 h05 作出阳性判断并提出修改，被证据门槛拒绝；B 的正常诊断有 1 例结构化缺失，C 有 2 例缺失。C 对 h07/h08 有潜在风险猜测，未明确确认实际凭据外泄。原始判断、系统确认、拒绝提案和落地修改分别保留。

3.3 两个代表案例

h01 参数日志。 凭据经 helper 参数进入 logging。A 的本项目启发式没有覆盖该参数日志传播，B 的候选仅有空白差异，两者仍泄露；C 修改日志内容并保留认证实参，最终通过。该例展示额外候选能力，不能外推为成熟扫描器缺陷或普遍优势。

h03 失败反馈。 第一候选将 credential= 替换为带 [REDACTED] 的前缀，真实值仍紧随其后。验证发现日志继续泄露，失败回执真实进入下一请求，第二候选改用固定错误详情后通过。模型一度把失败归因于字面词 credential，该解释错误，应以源码与值检测为依据。A 在此例首补丁已经成功，因此该案例证明存在一次真实反馈迭代，不证明 C 优于 A[5]。

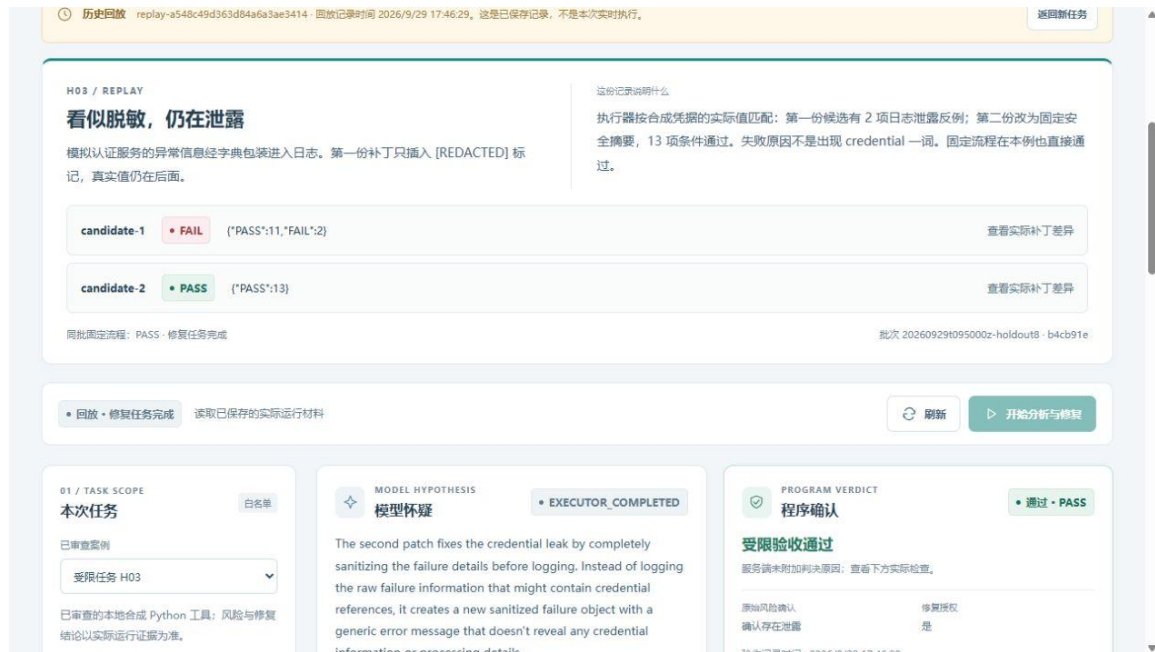


图 2 历史 h03 候选与反馈记录 真实记录回放

3.4 开销与解释范围

本轮 B 共 8 次请求，输入/输出 tokens 为 12,567/4,634；C 共 31 次，99,142/6,648。方法耗时累计 A 33.538 秒、B 57.178 秒、C 74.335 秒；它们包括

各自实际控制流和检查工作，不能当作严格等预算速度比较。D 仅在 h01/h03 各生成三份独立无反馈候选，六份均未修复日志泄露；C 与 D 最大输出额度相同，实际输入 tokens、调用次数不相同，不用 D 结果证明等算力优势。

第四章 创新性说明

4.1 让运行证据约束模型修改

针对无硬编码的运行时凭据路径，将允许认证通道和禁止输出通道明确区分，把“模型认为有问题”与“程序确认可以修改”分开。候选生成具备可审计的授权依据，正常代码可在模型建议错误时保持不变。

4.2 同时验收修复结果与任务过程

把代码对象是否通过、证据是否适用、模型是否实际调用工具、任务是否完成分别记录。执行器依据当前对象的必要条件停止，避免把文字成功或原对象通过误算为闭环完成。h03 的失败反馈和 h05/h06 的未完成状态构成正反两类可核对证据。

4.3 将过程记录转为可复检成果

单页把模型原文、证据、差异及独立状态连到具体记录，材料包在重读对象后重新检查。此处的创新主张是面向明确受限问题的工程组织与验证方式，不是首创安全算法、基础模型、操作系统沙箱或一般修复证明。

第五章 总结

作品已经形成运行时观察、证据授权、候选副本、隔离验收和材料复检的可运行原型。同轮八例显示，Agent 能为部分结构提供额外修复候选，也会产生格式失败、无依据怀疑和错误根因解释；固定程序更简单，完整任务数在该轮反而更多。因此本项目保留固定流程作为执行依据，把 Agent 定位为受约束的候选组件。

后续先改进工具协议的稳定性、无依据提案处理和过程可读性，再按新冻结版本扩大不同作者、不同结构的独立测试。已知案例复跑与新评估分别登记。未计划以真实凭据、任意仓库或外部服务扩大演示范围，未承诺普遍检出率、无人监督修复或正式安全认证。

来源与 AI 参与披露

公开模型、框架、推理服务和隔离基础设施按来源引用；本项目编写受限工具接口、会话授权与完成控制、固定裁判、案例、实验组织、材料复检和展示组件。ChatGPT/Codex 实质参与方案、主要代码生成与修改、调试、试验组织、结果核对和文稿准备，不能仅表述为语言润色。队伍实际成员贡献另列，身份字段待填。AI 辅助允许范围、独立研究要求及参赛资格须由队伍向导师/组委会确认；本报告不是签署的原创性声明。

参考文献

- [1] Qwen Team. Qwen-Agent 官方项目[EB/OL].
<https://github.com/QwenLM/Qwen-Agent>. 本项目使用 0.0.34，实际依赖锁与来源清单随材料提供。
- [2] Qwen Team. Qwen3-Coder 官方项目[EB/OL].
<https://github.com/QwenLM/Qwen3-Coder>. 本项目使用 Ollama 分发的 qwen3-coder:30b Q4_K_M，不开展训练。
- [3] Ollama. Ollama 官方项目[EB/OL]. <https://github.com/ollama/ollama>. 本轮推理版本 0.34.4。
- [4] 本项目. 冻结八案例完整运行记录[DS]. 2026-09-29. results.json; 冻结文件摘要; 源码快照; 分层事实审计。
- [5] 本项目. h03 原始候选与反馈记录[DS]. 2026-09-29. 首候选; 第二候选; 失败进入下一请求。